# Understanding Cloud Security Policy: NIST's Recommendations

Written by RSI Security in Incident Management

As more organizations adopt cloud computing solutions into their IT infrastructure, there is a greater need to strengthen cloud security. The NIST provides recommendations for optimizing clou organizations safeguard their cloud computing assets. Read on to learn

Ask me anything...

how a cloud security policy NIST recommendations can bolster your cloud security.

## What are the Cloud Security Policy NIST Recommendations?

Based on the National Institute of Standards and Technology (NIST) framework "Managing Risk in the Cloud," organizations can optimize their cybersecurity controls and implementations to achieve high standards of cloud security.

Understanding which cloud security policy NIST recommendations apply to your organization will help you:

- Develop a risk-based cloud security framework
- Manage cloud security risks as a cloud provider
- Manage cloud security risks as a consumer

Although the cloud security policy NIST recommendations apply to any organization, it is essential to optimize the recommendations to your unique security needs—with the help of a cloud security partner.

### How Can NIST's Cloud Security Recommendations Help You?

When adopting cloud-based IT solutions, organizations typically choose between managing cloud computing assets internally or outsourcing them to a cloud services provider.

Outsourcing the management of your cloud computing assets provides a greater level of security assurance than with those managed internally because of the optimized security controls often implemented by cloud providers. Ultimately, implementing any cloud-based solutions requires an assessment of the security and privacy risks and the potential impact of these threats on any sensitive data you store or process.

Implementing the cloud security policy NIST recommendations will help guide the management of your cloud computing infrastructure and

minimize the impact of cloud security threats on:

- Critical digital assets, including:
  - Cloud databases for large-scale data storage
  - Systems used to host cloud-based applications
- Individuals and stakeholders, including:
  - Customers whose sensitive data is stored in the cloud
  - Employees whose records are stored in the cloud
  - External stakeholders whose confidential information is stored in the cloud
- Operations involving:
  - Mission-specific objectives
  - The reputation of your organization

By following and optimizing the cloud security policy NIST recommendations, your organization will remain steps ahead of cybercriminals and malicious individuals looking to exploit gaps in your cloud security infrastructure.

Request a Free Consultation

**NIST Cloud Security Risk Management Processes**

The NIST views risk management holistically and recommends that organizations develop a set of coordinated risk management activities to effectively address cloud security risks.

Per the NIST, risk management can be grouped into three categories:

- Organization-level risks
- Mission and business process-level risks
- Information system-level risks

A critical part of implementing cloud security policy NIST risk management successfully is ensuring that your organization develops processes to:

- Assess risks by leveraging proven cloud security threat detection strategies
- Mitigate risks by implementing controls to address gaps in cloud security
- Control risks by continuously evaluating the posture of your cloud security infrastructure

The coordination of cloud security risk management processes can be streamlined using a system development life cycle (SDLC), which helps:

- Secure each step of the system development process, including:
  - Initiation of cloud security systems
  - Analysis of the feasibility of security controls and related risks
  - Design of security controls and systems
  - Implementation and configuration of cloud security controls
  - Maintenance of systems with periodic configuration management
  - Disposal of end-of-life components (e.g., software, hardware, systems)
- Identify the most critical assets to secure based on cloud security gaps or vulnerabilities
- Swiftly identify security vulnerabilities and initiate appropriate remediation measures
- Guide decision-making activities for all cloud security implementations
- Streamline and improve interoperability and the integration of cloud security across the organization

The benefit of integrating SDLC processes into your organization's cloud security policy NIST risk management is that you can optimize each stage according to your current needs and priorities. Incorporating SDLC processes into cloud security risk management will also guide the development of a risk management framework and streamline risk management for both cloud service providers and consumers.

# Developing a Risk Management Framework

Before addressing cloud security risk management for all stakeholders involved, you must develop a framework to assess, treat, and control risks. The most important aspects of a cloud security policy NIST risk management framework are identifying:

- The likelihood of occurrence of threat risks
- Which vulnerabilities can be exploited, should a cyberattack occur
- The impact of cyberattacks that exploit security vulnerabilities
- Which cloud assets are most likely to be affected by cyberattacks

Per the NIST, cloud security risk management must be a holistic process that covers:

- Planning of cloud security systems
- Development of cloud security systems
- Allocation of security controls and implementations
- Ongoing security monitoring

A risk management framework (RMF) helps structure cloud security risk management into the SDLC, primarily operating at the information system level. Ideally, it also extends out to the organization and business process levels, minimizing risks across all departments.

### Steps of the NIST Cloud Security RMF

The NIST RMF process (sourced from NIST SP 800-37) is standardized across traditional information systems and provides best practices for implementing robust system development processes. Furthermore, the steps of the NIST RMF can be applied to any information system.

Most importantly, the security requirements within the NIST RMF must be defined, researched, and optimized from the initiation of system development. Essentially, developing your cloud security systems requires the integration of the RMF early on and not as patch solutions independent of the SDLC.

To help organizations achieve effective cloud security, the RMF comprises six steps, grouped into the following categories:

- Risk assessment (Steps 1 and 2)
- Risk treatment (Steps 3 to 5)
- Risk control (Step 6)

The six steps of the RMF can serve as a cloud security risk assessment checklist and are further broken down as follows:

- **Step 1** – The information processed, stored, or transmitted by a cloud security solution must be categorized based on a system impact analysis of:
    - Operational requirements
    - Cloud security requirements
    - Data privacy requirements
    - Performance requirements
- **Step 2** – The baseline cloud security controls and capabilities must be optimized or supplemented based on:
    - Assessment of cloud security risks
    - Conditions within the cloud operating environment
    - Results of monitoring the effectiveness of cloud security
    - Documentation of the proposed, reviewed, and approved cloud security plan
    - The most appropriate cloud security architecture for your organization
- **Step 3** – Cloud security controls should be implemented along with a description of the:

    - Deployment of the controls within the cloud infrastructure
    - Operating environment of the controls
- **Step 4** – Cloud security controls offered by a cloud provider should also be assessed via the procedures listed in the security assessment plan to determine the:
    - Proper implementation of controls
    - Effectiveness of controls against desired outcomes
- **Step 5** – Operationalization of cloud security controls is authorized following the determination of acceptable operating risks to your organization's assets, individual users, and other stakeholders.
- **Step 6** – Once operationalized, cloud security controls should be routinely monitored to:
    - Assess the effectiveness of controls against security requirements
    - Document changes to the cloud infrastructure and operating environment
    - Analyze the impact of changes to the security controls
    - Report any noteworthy changes to the cloud security posture

Implementation of these steps should be conducted by designated individuals or teams within your organization's IT department, including any relevant stakeholders. Furthermore, the RMF will help streamline cloud security policy NIST implementation for each iteration of the SDLC.

As a cloud consumer, it is ultimately your responsibility to ensure that the cloud services you receive are up to NIST security standards and can effectively secure the privacy of your sensitive data on the cloud.

## Risk Management for Cloud Providers

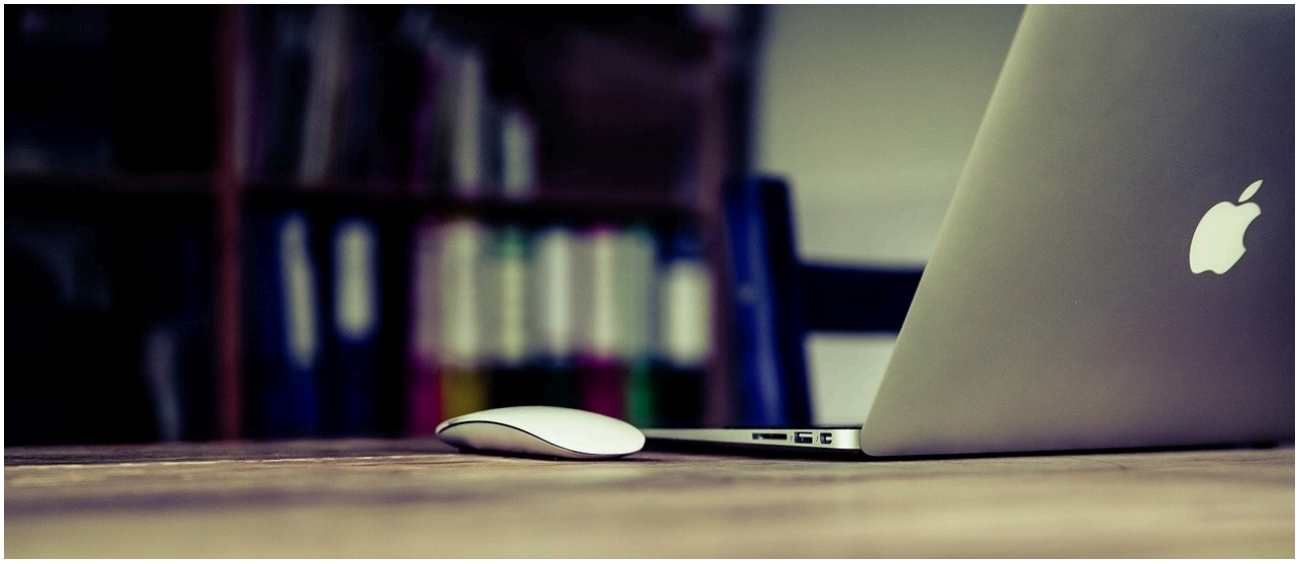
Most cloud providers integrate security and privacy controls into their cloud computing solutions, ensuring that these solutions meet baseline regulatory requirements. Given the multiplicity of organizations served, there is often little to no need for cloud security optimization.

For cloud *providers*, the most important cloud security policy NIST recommendations pertain to:

- **Regulatory compliance** – Cloud providers must comply with the security requirements of regulatory frameworks to ensure utmost data privacy and security across industries. Compliance with cloud security requirements is typically necessary for frameworks such as:
    - PCI DSS for organizations that process card payment transactions
    - HIPAA for organizations within and adjacent to healthcare
    - GDPR for organizations with customers who are European Union (EU) citizens
- **Optimized security** – Unlike traditional IT systems that are typically segmented and distributed across physical locations, cloud solutions are centralized, making it easier for cloud providers to develop specialized cloud security solutions that meet the needs of customers.

The benefit of implementing standardized risk management processes such as the NIST's recommended steps is that they are tested and vetted across multiple organizations.

However, cloud providers must also be aware that some cloud consumers will have gaps and vulnerabilities on their end of the cloud security infrastructure. Nonetheless, the cloud security policy NIST recommendations will help cloud providers manage risk more efficiently.



## Risk Management for Cloud Consumers

For cloud consumers, the cloud security policy NIST recommendations will apply if an organization is willing to define and understand:

- The unique characteristics of its cloud infrastructure
- Each of the components of its cloud service
- The roles of each actor in managing cloud security risks

More importantly, risk management for cloud consumers requires:

- Identification of the security and privacy controls specific to cloud environments
- Due diligence to verify the stipulation of control requirements and implementations in cloud provider service agreements
- Assessment of the implemented controls listed in cloud security policies
- Ongoing monitoring of all security and privacy controls

Implementing the steps listed in the NIST RMF to optimize cloud security as a consumer enables robust risk management. Functioning as a cloud risk assessment checklist, the RMF will help manage risk to cloud infrastructure.

**How Can the RMF Steps Help Cloud Solution Consumers?**

To further optimize cloud security risk management, cloud consumers must identify which cloud service best fits their business and mission-critical needs while maintaining a high level of data privacy and security.

When adopting a cloud-based solution, the NIST recommends that cloud consumers follow nine steps to implement the RMF and manage risks to cloud security:

- Define which services or applications the cloud-based solution will support
- Determine which functional capabilities are required for the cloud-based service
- Identify the privacy and security requirements necessary to implement robust security controls for the cloud-based service, ensuring compliance with NIST security category requirements
- Implement the most appropriate cloud environment architecture that combines both cloud deployment and cloud service models,

including:
    - Public deployment models with IaaS, PaaS, or SaaS
    - Private deployment models with IaaS, PaaS, or SaaS
    - Hybrid deployment models with IaaS, PaaS, or SaaS
    - Community deployment models with IaaS, PaaS, or SaaS
- Designate the actors responsible for each cloud service environment or ecosystem (e.g., cloud providers, cloud service brokers)
- Develop an understanding of the security posture of the cloud provider or broker, ensuring:
    - Implementation of baseline security controls
    - Compliance with privacy and security requirements
    - Presence of the necessary additional compensating controls
- Assign and document security parameters that align with organization-specific needs and security requirements
- Establish additional internal enhancements to the baseline security and privacy controls instituted by the cloud provider
- List additional specifications for any implementations of security and privacy controls that do not meet baseline security requirements

For a cloud consumer, the RMF serves as a cloud security risk assessment checklist and helps stakeholders assess the security posture of the services offered by cloud providers. As a cloud service consumer, the risk management process highlighted in the cloud security policy NIST RMF will help you negotiate security requirements for all cloud services you outsource.

However, working with a cloud security partner will help you navigate the cloud security policy NIST recommendations and more effectively secure your cloud infrastructure.

## Operationalize Your NIST Cloud Security Policy

Securing your digital assets on the cloud is essential to maintaining industry-standard data privacy and security. By leveraging the cloud